Incident report analysis

Summary	The company's internal network stopped responding for a while and nobody could use the network services. The security team found that the cause was a flood of ICMP packets coming from outside, which makes it a distributed denial of service (DDoS) attack. To get back to work, the team blocked the incoming ICMP traffic and shut down the non-critical services, so the critical ones could be restored first. Identify, Protect and Detect below describe what the company changes after this incident to be better prepared. Respond and Recover describe how the incident itself is handled.
Govern	Someone has to own these decisions before the next attack. I would write down who can approve blocking traffic or shutting down non-critical services, and which services count as critical, so the team does not have to argue about it in the middle of an outage. Management should also review the firewall and ICMP rules on a regular schedule, not only after something breaks.
Identify	The company was hit by an ICMP flood. The weak point was a firewall that did not limit incoming ICMP packets, so the attacker could overload the whole internal network. Everything that depends on the network was affected, which means the critical resources have to be identified in advance and protected first.
Protect	A new firewall rule now limits how fast ICMP packets can enter the network. The team also added an IDS/IPS that filters out ICMP traffic with suspicious characteristics.
Detect	The firewall now checks the source IP address of incoming ICMP packets to catch spoofed addresses. Network monitoring software was added to spot abnormal traffic patterns early.
Respond	Next time we will isolate the affected systems first, so the problem does not spread. Then we restore the critical systems and services, read the network logs looking for anything strange, and report the incident to management and, when the law requires it, to the authorities.
Recover	To recover from an ICMP flood, the external ICMP traffic is blocked at the firewall and the non-critical services are stopped to lower the load inside the network. The critical services come back first. When the flood has timed out, the rest of the services can be restored.

Reflections/Notes	One firewall rule and one monitoring tool could have saved the company a long outage. I also learned that a response needs an order: block the traffic, lower the load, bring back what is critical, then the rest. What I learned here goes back into every function above, starting with Govern.